



Name: Kavita Prajapati

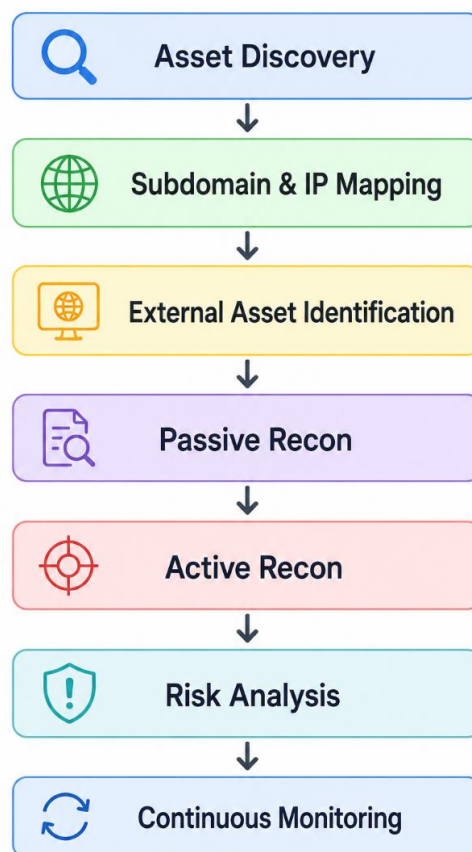
Team: Attack Surface Management (VAPT)

Introduction

- Attack Surface Management (ASM) is the process of finding and keeping track of all
- internet-exposed assets like domains, IPs, APIs, and cloud services.
- Since systems keep changing, new risks can appear without notice.
- ASM helps security teams stay aware of what's exposed and spot unknown assets.
- By continuously monitoring and analyzing, it helps reduce risks and improve overall security.

And here I am presenting ASM through some diagram which shows clear version, steps and tools :

ASM Workflow Diagram:





Explanation:

Asset Discovery: Find all domains, subdomains, and IPs related to the organization.

EX: example.com, api.example.com, 192.168.1.1

Subdomain & IP Mapping: Understand how these assets are connected and linked.

EX: api.example.com → points to IP 192.168.1.1

External Asset Identification: Check what assets are publicly exposed on the internet.

EX: A public login page like login.example.com

Passive Recon: Collect information without directly interacting with the target.

EX: Finding subdomains using public sources like DNS records

Active Recon: Interact with systems to gather deeper technical details.

EX: Scanning open ports like 80 (HTTP) or 443 (HTTPS)

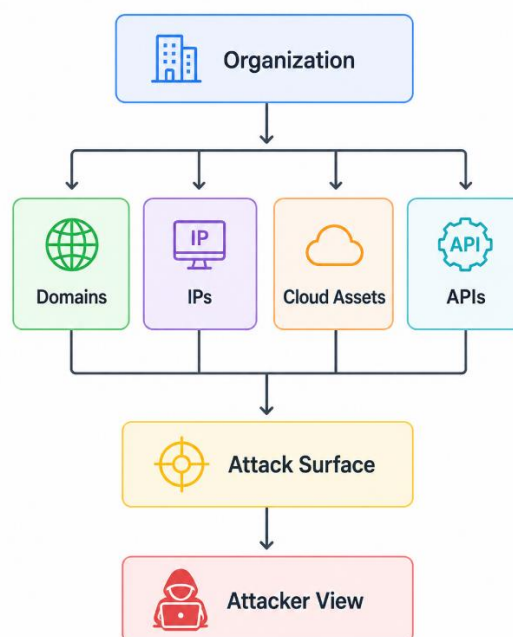
Risk Analysis: Identify and prioritize possible security risks.

EX: Detecting an open port with an outdated service

Continuous Monitoring: Keep tracking assets to detect new changes or threats over time.

EX: Noticing a new subdomain like dev.example.com appears

Attack Surface Workflow Diagram:





Explanation:

Organization: The company or target whose assets are being analyzed.

EX: example.com company

Domains: Main websites and their subdomains owned by the organization.

EX: example.com, shop.example.com

IPs: The IP addresses linked to those domains and servers.

EX: 192.168.1.1

Cloud Assets: Resources hosted on cloud platforms.

EX: AWS S3 bucket like example-data.s3.amazonaws.com

APIs: Endpoints used for communication between applications.

EX: api.example.com/v1/users

Attack Surface: All publicly exposed assets combined that attackers can target.

EX: Open ports, login pages, APIs, cloud storage

Attacker View: How an attacker sees and tries to find weaknesses in these assets.

EX: Finding an open login page or misconfigured API

ASM Tools:

Asset Discovery:

Subfinder — Finds subdomains from public sources.

Ex: Finds api.example.com

Amass — Discovers and builds a full map of domains and related assets.

Ex: Maps dev.example.com with its IP

Assetfinder — Quickly collects subdomains with simple queries.

Ex: Finds shop.example.com

Subdomain & IP Mapping:

Shodan — Shows which services are running on an IP.

Ex: Finds port 22 open on a server

MassDNS — Resolves a large number of domains to IPs very fast.

Ex: api.example.com → 192.168.1.1



External Asset Identification:

Censys — Searches for exposed systems and certificates on the internet.

Ex: Finds SSL cert linked to example.com

ZoomEye — Searches for exposed services and devices on the internet.

Ex: Finds open web server on port 80

Passive Recon:

theHarvester — Collects emails, domains, and info from public sources.

Ex: Finds admin@example.com

crt.sh — Finds subdomains from SSL certificate data.

Ex: Finds secure.example.com

Wayback URL/Machine — Shows old versions of websites.

Ex: Finds hidden old endpoint /admin

Active Recon:

Nmap — Scans systems to find open ports and services.

Ex: Detects 80 (HTTP) and 443 (HTTPS)

RustScan — Quickly scans ports and passes results to deeper tools.

Ex: Finds open port 22 and 443

Httpx — Checks which domains are live and running web services.

Ex: Confirms api.example.com is active

Risk Analysis:

Nuclei — Detects known vulnerabilities using templates.

Ex: Finds outdated software issue

OpenVAS — Performs deep vulnerability scanning on systems.

Ex: Finds weak SSL configuration

Nikto — Scans websites for common security issues.

Ex: Finds exposed server info

Continuous Monitoring:

Nuclei — Runs automated scans regularly for new issues.

Ex: Detects new vulnerability after update



Subfinder — Can be used repeatedly to track newly appearing subdomains.

Ex: Detects new subdomain like test.example.com

Conclusion:

Attack Surface Management is basically about knowing what of your system is visible on the internet and keeping an eye on it. It helps you find hidden or forgotten assets and fix problems before someone else finds them. Since things keep changing, you have to keep checking regularly. In simple terms, it's like checking your house again and again to make sure everything is safe and nothing is left open.